Università degli Studi di Messina

Department of Mathematical and Computer Sciences, Physical Sciences and Earth Sciences

Bachelor's Degree in Computer Science (L-31)

Path: **Data Analysis**

Course**: System Security**

Project Title

S3-Factor Authentication Social Blog App

Prepared by: Abenezer D. Regasa
Matriculation ID: 562763

Supervisor: Prof. Massimo Villari

Messina, Sicily, Italy
February, 2026

1. Introduction

This project presents the design and implementation of a secure social blogging application that integrates multiple security mechanisms to protect user accounts and system resources.

Traditional systems often rely solely on password-based authentication, which is vulnerable to various attacks such as brute-force attempts, credential leaks, and password reuse. To address these issues, this project implements a three-factor authentication system combined with token-based authorization.

The system is developed using a Flutter mobile frontend, a Flask backend API, and a MySQL database, with a strong focus on applying core security concepts including authentication, authorization, and secure data handling.

2. System Overview

The application allows users to:

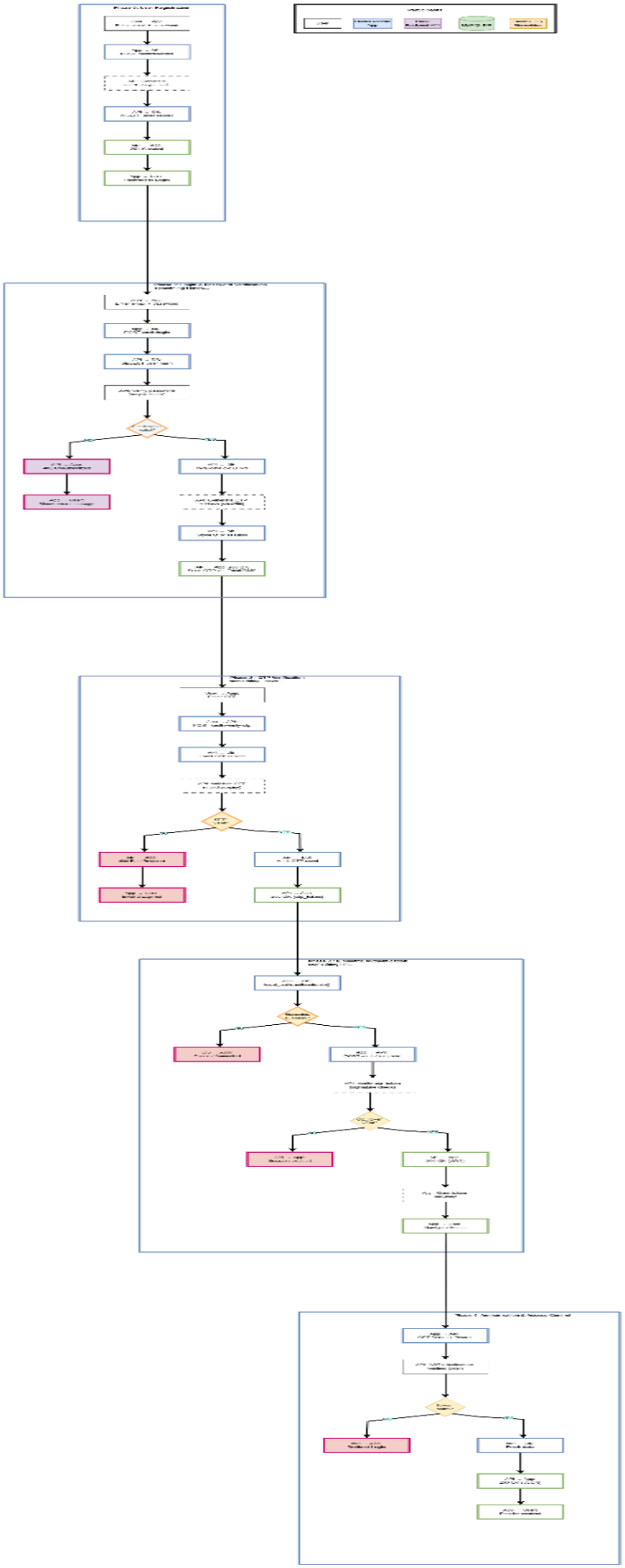
1. Register and log in securely
2. Create posts
3. Like and comment on posts
4. Manage their own content

Security is enforced at multiple levels to ensure that only authenticated and authorized users can access system functionalities.

The **system architecture** consists of:

1. **Frontend (Flutter):** Handles user interaction and biometric authentication
2. **Backend (Flask):** Handles authentication, authorization, and business logic
3. **Database (MySQL):** Stores users, posts, and OTP-related data securely

3-Factor Authentication & Authorization Flow – Social Blog App



3. Authentication Mechanism

The system implements three-factor authentication (3FA) based on:

1) **Something the user knows:** Password
2) **Something the user has:** One-Time Password (OTP)
3) **Something the user is:** Biometric authentication

The authentication process follows a sequential flow:

1. The user enters email and password
2. The backend verifies credentials using secure hashing
3. An OTP is generated and sent to the user
4. The user submits the OTP for verification
5. The system triggers biometric authentication on the device
6. Upon success, the user is granted access

This layered approach significantly increases resistance against unauthorized access.

4. Password Security

Passwords are securely handled using bcrypt hashing with salt.
Before applying bcrypt, the password is preprocessed using SHA-256 to ensure consistent input size. The final hashed password is stored in the database.

This approach provides protection against:

1. Brute-force attacks
2. Rainbow table attacks
3. Database leaks

Importantly, passwords are never stored in plaintext, ensuring confidentiality even if the database is compromised.

5. OTP-Based Verification

The second authentication factor is implemented using a One-Time Password (OTP) system.

Key security features include:

1. OTP is hashed using SHA-256 with a salt before storage
2. OTP has a limited validity period (5 minutes)
3. OTP is marked as used after successful verification

Any previously generated OTP is invalidated when a new one is created

These measures prevent:

1. Replay attacks
2. OTP reuse
3. Unauthorized access through intercepted codes

This ensures that only the most recent and valid OTP can be used for authentication.

6. Biometric Authentication

The third authentication factor is biometric verification, implemented on the client side using the device's secure authentication system.

Biometric authentication:

1. Uses the device's secure hardware (e.g., fingerprint sensor)
2. Does not expose or store biometric data within the application
3. Only returns a success or failure response

This adds an additional layer of protection by ensuring that only the legitimate device user can finalize the login process.

7. Authorization and Access Control

After successful authentication, the system enforces authorization using JSON Web Tokens (JWT).

1. Each authenticated user receives an access token
2. All protected API endpoints require this token
3. A middleware verifies the token before granting access

If the token is missing or invalid, access is denied.
Additionally, the system enforces resource-level authorization:

1. Only the creator of a post can delete it
2. Unauthorized actions are blocked with appropriate responses

Authorization is also partially enforced at the UI level, where certain actions (e.g., delete button) are only visible to the resource owner. However, backend validation remains the primary security control.

8. Security Design Principles

The system follows a layered security approach, where multiple independent mechanisms protect against different threats.

Key principles applied include:

1. **Defense in depth**: Multiple authentication layers
2. **Least privilege:** Users can only perform allowed actions
3. **Secure storage:** Sensitive data is hashed
4. **Separation of concerns:** Frontend and backend responsibilities are clearly defined

Even if one layer is compromised, other layers continue to protect the system.

Limitations and Future Improvements

Although the system provides strong security, several improvements can be considered:

1. Implementation of refresh tokens for session management
2. Addition of rate limiting to prevent brute-force attempts
3. Device binding for stronger identity verification
4. Logging and monitoring for detecting suspicious activities

These enhancements would further strengthen the system's resilience.

10. Conclusion

This project demonstrates how combining authentication and authorization mechanisms can significantly improve system security.

By integrating password security, OTP verification, biometric authentication, and token-based authorization, the system provides a robust defense against unauthorized access.

The implementation reflects real-world security practices and highlights the importance of applying theoretical concepts in practical systems.

11. References

Security in Computing, 5th Edition – Pfleeger et al.
Course Lecture Slides: Authentication, Access Control, Cryptography
bcrypt Documentation
JSON Web Token (JWT) Documentation
Flask Documentation
Flutter Documentation